CTI—Helios Energy

1. Installation de MISP avec Docker

On installe Docker compose :
sudo apt install docker.io docker-cli docker-compose git
sudo systemctl enable --now docker

Nous allons maintenant récupérer les fichiers officiels de MISP.
git clone https://github.com/MISP/misp-docker.git
cd misp-docker
cp template.env .env
chmod 600 .env
sudo docker compose config --quiet

Nous modifions le fichier .env avec nano et nous y ajoutons notre mot de passe :
sudo docker compose pull
Le téléchargement a réussi, on lance la commande afin de lancer les conteneurs :
sudo docker compose up -d
sudo docker compose ps
Les services ont démarré, on ouvre cette adresse dans un navigateur :http://localhost:8080

Nous nous connectons avec :

- **Identifiant :** admin@safia.test
- **Mot de passe :** celui qu'on a enregistré dans le fichier nano/.env

2. Enregistrement des indicateurs

Le corpus comprend 40 indicateurs et trois fiches d'analyse de binaires. Les indicateurs ont été structurés dans MISP et associés aux objets et relations documentés.

Tableau récapitulatif

3. Reconstitution de la chaîne d'attaque

Nous pouvons maintenant passer à **la reconstitution de la chaîne d'attaque**, à partir des 12 alertes SIEM, des fiches et des journaux :

Date — mars 2026	Éléments observés
2 mars	Pièce jointe malveillante sur comptabilite-07, lancement de PowerShell, téléchargement de BIN-02, persistance et communications de commande
3 mars	Balayage du réseau interne depuis le poste compromis
4 mars	Connexion RDP inhabituelle sur srv-fichiers-02, puis injection dans explorer.exe
5 mars	Accès à LSASS sur dc-01, activité autour d'un compte de service, préparation de données et exfiltration signalée de 2,3 Go
6 mars	Contact d'un domaine de repli
7 mars	Tentative d'effacement des journaux sur le poste initial

4. Analyse de la chaîne d’attaque

4.1. Accès initial et exécution sur comptabilite-07

Le 2 mars 2026 à 08 h 30 UTC, le classeur malveillant facture_mars_2026.xlsm (BIN-01), reçu par courriel, est signalé sur le poste comptabilite-07. Selon sa fiche d’analyse, l’ouverture du document déclenche une macro VBA qui lance PowerShell en fenêtre masquée.

À 08 h 31 UTC, l’alerte SIEM nº 1 et le journal Sysmon indiquent qu’un processus Office lance PowerShell avec une commande encodée. Cette observation étaye l’exécution de PowerShell, mais présente une incohérence : le journal mentionne winword.exe, alors que BIN-01 est un classeur Excel. Cet écart doit être conservé comme limite du dossier.

Techniques ATT&CK à retenir pour cette étape :

- T1566.001 — Spearphishing Attachment : pièce jointe malveillante reçue par courriel, selon la fiche BIN-01.
- T1204.002 — Malicious File : ouverture du fichier par l’utilisateur, selon la fiche BIN-01.
- T1059.001 — PowerShell : exécution décrite dans la fiche et corroborée par l’alerte nº 1 et le journal Sysmon.

Sources : 01_fiches_analyse_binaires.md, fiche BIN-01 ; 03_alertes_siem_12.csv, alerte nº 1 ; 05_journaux_bruts.log, événement du 2 mars 2026 à 08 h 31 UTC.

4.1.1 Téléchargement de la seconde charge BIN-02

Après l’ouverture du document malveillant, PowerShell télécharge svchost_update.exe (BIN-02) sur comptabilite-07, selon les fiches BIN-01 et BIN-02.

Les indicateurs nº 13 et nº 29 identifient le domaine cdn-svc-update[.]test et l’URL hxxps://cdn-svc-update[.]test/win/svchost_update.exe comme la source du téléchargement. Leur première observation est datée du 2 mars 2026 à 08 h 41 UTC.

À 08 h 42 UTC, l’alerte SIEM nº 2 signale ce téléchargement. Le journal Squid associé enregistre une requête vers le même fichier, une réponse HTTP 200 et un volume de 421 376 octets. Ce volume correspond à la taille de BIN-02 indiquée dans sa fiche, ce qui renforce la cohérence du rapprochement.

Technique ATT&CK retenue : T1105 — Ingress Tool Transfer. Le comportement observé correspond au transfert d’une charge depuis une infrastructure externe vers le poste compromis.

Sources : 01_fiches_analyse_binaires.md, fiches BIN-01 et BIN-02 ; 02_indicateurs_40.csv, indicateurs nº 13 et nº 29 ; 03_alertes_siem_12.csv, alerte nº 2 ; 05_journaux_bruts.log, événement Squid du 2 mars 2026 à 08 h 42 UTC.

Limites : les sources indiquent une première observation à 08 h 41 et une trace de téléchargement à 08 h 42 ; ces deux horaires sont conservés séparément. Le journal Squid ne fournit pas l’empreinte du fichier transféré et ne démontre pas, à lui seul, son exécution.

4.2. Persistance sur comptabilite-07

Le dossier décrit deux mécanismes de persistance : une valeur dans une clé de registre Run associée à BIN-01 et une tâche planifiée associée à BIN-02.

Persistance par clé de registre

Selon la fiche BIN-01, le programme écrit une valeur dans HKCU\Software\Microsoft\Windows\CurrentVersion\Run. L'indicateur nº 38 précise le nom WinTelemetry et une première observation le 2 mars 2026 à 08 h 44 UTC, avec une cote Admiralty A2.

Ce mécanisme permet de lancer un programme à l'ouverture de session de l'utilisateur concerné. Il correspond à T1547.001 — Registry Run Keys / Startup Folder.

Limite : le dossier ne fournit ni le contenu de la valeur WinTelemetry ni un journal de sa création. Le mécanisme est décrit dans la fiche et l'indicateur, mais son fonctionnement effectif après une nouvelle ouverture de session n'est pas démontré.

Persistance par tâche planifiée

Selon la fiche BIN-02, svchost_update.exe établit une persistance par une tâche nommée MicrosoftEdgeUpdateTaskMachine. L'indicateur nº 36 situe sa première observation le 2 mars 2026 à 08 h 45 UTC, avec une cote Admiralty A2.

À 08 h 46 UTC, l'alerte SIEM nº 3 et le journal Sysmon signalent la création d'une tâche portant ce même nom sur comptabilite-07. Ce comportement correspond à T1053.005 — Scheduled Task.

Limite : les éléments fournis ne précisent pas le programme lancé par la tâche, son déclencheur ou son compte d'exécution. Sa création est documentée ; sa configuration complète et ses exécutions ultérieures restent inconnues. Les horaires de première observation à 08 h 45 et de détection à 08 h 46 sont conservés séparément.

Sources : 01_fiches_analyse_binaires.md, fiches BIN-01 et BIN-02 ; 02_indicateurs_40.csv, indicateurs nº 36 et nº 38 ; 03_alertes_siem_12.csv, alerte nº 3 ; 05_journaux_bruts.log, événement Sysmon du 2 mars 2026 à 08 h 46 UTC.

Les correspondances ont été vérifiées dans les fiches MITRE : clé de registre Run — T1547.001 et tâche planifiée — T1053.005.

4.3. Communications de commande et contrôle de BIN-02

Selon la fiche BIN-02, svchost_update.exe contacte un serveur de commande en HTTPS toutes les 300 secondes environ, avec une variation aléatoire de ± 20 %. La balise contient le nom de la machine, l'utilisateur et ses privilèges. Ces caractéristiques sont décrites dans la fiche d'analyse ; le contenu des échanges n'est pas fourni dans les journaux.

Les indicateurs nº 14 et nº 31 associent ces communications au domaine api-telemetry-eu[.]test et à l'URL hxxps://api-telemetry-eu[.]test/v2/beacon, observés pour la première fois le 2 mars 2026 à 09 h 15 UTC. L'indicateur nº 20 donne l'adresse de résolution 198.51.100.24.

À 09 h 16 UTC, l’alerte SIEM nº 4 signale des connexions périodiques depuis comptabilite-07 vers ce domaine. Le journal Zeek enregistre une connexion vers 198.51.100.24 sur le port 443, annotée « beacon ». Cette trace est cohérente avec la destination indiquée dans les indicateurs.

Technique ATT&CK retenue : T1071.001 — Web Protocols. L’utilisation de HTTPS pour les communications de commande et contrôle est décrite dans la fiche BIN-02 et cohérente avec l’URL fournie.

Limites : une seule connexion est présente dans l’extrait de journal. Elle ne suffit pas à mesurer la périodicité ni la variation de ± 20 %. Le port 443 ne démontre pas à lui seul l’utilisation de HTTPS. Les commandes reçues et leur exécution ne sont pas visibles.

La fiche BIN-02 cite également T1573 — Encrypted Channel. Cette correspondance reste à confirmer : les éléments fournis décrivent HTTPS, mais ne précisent pas de chiffrement supplémentaire propre au programme, au-delà de celui du protocole.

Sources : 01_fiches_analyse_binaires.md, fiche BIN-02 ; 02_indicateurs_40.csv, indicateurs nº 14, nº 20 et nº 31 ; 03_alertes_siem_12.csv, alerte nº 4 ; 05_journaux_bruts.log, événement Zeek du 2 mars 2026 à 09 h 16 UTC.

4.4. Découverte des services du réseau interne

Le 3 mars 2026 à 10 h 13 UTC, l’alerte SIEM nº 6 signale un balayage du réseau 10.20.0.0/16 sur les ports 445 et 3389. L’alerte est associée au poste comptabilite-07 et indique l’adresse source 198.51.100.55.

Le journal Zeek au même horodatage décrit également ce balayage. L’indicateur nº 25 mentionne cette adresse dans le contexte d’un balayage interne observé depuis le poste compromis, avec une première observation à 10 h 12 UTC et une cote Admiralty B3.

L’activité est compatible avec une recherche de services SMB et RDP, habituellement associés aux ports 445 et 3389. Elle pourrait préparer un déplacement vers d’autres machines, mais le balayage seul ne démontre ni une connexion réussie ni leur compromission.

Technique ATT&CK retenue : T1046 — Network Service Discovery, dans la tactique Discovery. Le comportement observé correspond à une recherche de services accessibles sur le réseau.

Limites : le dossier ne fournit pas les réponses au balayage, la liste des machines accessibles ou le programme utilisé. Le lien exact entre comptabilite-07 et l’adresse source 198.51.100.55 n’est pas explicité. Aucun élément ne permet d’attribuer directement cette action à BIN-02.

Sources : 02_indicateurs_40.csv, indicateur nº 25 ; 03_alertes_siem_12.csv, alerte nº 6 ; 05_journaux_bruts.log, événement Zeek du 3 mars 2026 à 10 h 13 UTC.

4.5. Connexion RDP inhabituelle sur srv-fichiers-02

Le 4 mars 2026 à 01 h 48 UTC, l’alerte SIEM nº 7 signale une connexion RDP hors horaires ouvrés sur srv-fichiers-02. Son détail situe l’ouverture de session à 01 h 47 et mentionne une source interne inhabituelle.

Le journal Security associé rapporte un événement 4624, avec un type de connexion 10, identifié comme RDP, et le compte svc-backup-temp. Cette trace étaye une ouverture de session à distance

réussie. L’horaire et le contexte de l’incident rendent cette connexion suspecte, sans suffire à prouver qu’elle est malveillante.

L’indicateur nº 26 associe l’adresse 203.0.113.44 à une connexion RDP entrante à 01 h 47, avec une cote Admiralty C3. Toutefois, l’alerte et le journal ne précisent pas cette adresse : son lien avec la session observée reste à confirmer.

Correspondance ATT&CK : T1021.001 — Remote Desktop Protocol, dans la tactique Lateral Movement. L’utilisation de RDP est documentée ; son emploi par l’attaquant pour se déplacer vers srv-fichiers-02 reste une hypothèse.

Incohérence chronologique : le compte svc-backup-temp apparaît dans cette session du 4 mars, alors que l’indicateur nº 37 et l’alerte nº 9 décrivent sa création sur le contrôleur de domaine le 5 mars. Le dossier ne précise pas s’il s’agit du même compte, d’un compte local homonyme ou d’une erreur de chronologie. Cette incohérence doit être conservée et soumise au formateur.

Limites : la machine d’origine, le domaine du compte, ses privilèges et les actions réalisées pendant la session ne sont pas fournis. Nous ne pouvons pas établir un trajet direct depuis comptabilite-07 ni expliquer comment les identifiants ont été obtenus.

Sources : 02_indicateurs_40.csv, indicateurs nº 26 et nº 37 ; 03_alertes_siem_12.csv, alertes nº 7 et nº 9 ; 05_journaux_bruts.log, événement Security du 4 mars 2026 à 01 h 48 UTC.

La correspondance est vérifiée dans la fiche MITRE T1021.001.

4.6. Injection de code dans explorer.exe sur srv-fichiers-02

Le 4 mars 2026 à 11 h 05 UTC, l’alerte SIEM nº 8 signale une région mémoire exécutable anormale dans explorer.exe sur srv-fichiers-02. Le journal Sysmon associé mentionne une opération CreateRemoteThread visant explorer.exe et une région mémoire RWX, c’est-à-dire accessible en lecture, écriture et exécution.

Ces observations sont compatibles avec une injection de code dans un processus légitime. Dans le contexte de l’incident, elles renforcent le soupçon d’une activité malveillante sur le serveur de fichiers.

La fiche BIN-02 décrit une capacité d’injection dans explorer.exe par Process Hollowing. L’indicateur nº 11 fournit également l’empreinte SHA-256 d’un module présenté comme injecté par BIN-02 dans ce processus, avec une première observation à 11 h 06 UTC et une cote Admiralty B2.

Correspondances ATT&CK :

- T1055 — Process Injection : retenue pour l’activité observée sur srv-fichiers-02.
- T1055.012 — Process Hollowing : décrite dans la fiche BIN-02, mais non démontrée par le seul journal fourni pour cet événement.

Limites : une opération CreateRemoteThread et une région mémoire RWX ne suffisent pas à identifier précisément un Process Hollowing. Le journal ne donne ni le processus à l’origine de l’opération ni l’empreinte du code injecté. Le rattachement de cet événement à BIN-02 repose donc sur les indications du dossier, sans confirmation directe dans cette trace.

L’alerte et le journal sont datés de 11 h 05, tandis que l’indicateur du module mentionne 11 h 06. Ces horaires sont conservés séparément. Aucun élément ne démontre que cette injection résulte de la session RDP précédente ou qu’elle a permis une élévation de privilèges.

Sources : 01_fiches_analyse_binaires.md, fiche BIN-02 ; 02_indicateurs_40.csv, indicateur nº 11 ; 03_alertes_siem_12.csv, alerte nº 8 ; 05_journaux_bruts.log, événement Sysmon du 4 mars 2026 à 11 h 05 UTC.

Nous distinguons ainsi **l’injection observée** de sa forme précise, le Process Hollowing — T1055.012, décrite dans la fiche.

LSASS est un processus Windows lié à l’authentification. Sa mémoire peut contenir des éléments d’identification que les attaquants cherchent à récupérer pour accéder à d’autres ressources. Cela correspond à T1003.001 — LSASS Memory.

4.7. Accès à la mémoire LSASS sur dc-01

Selon la fiche BIN-03, rundll32_helper.dll est récupéré sur le contrôleur de domaine dc-01 après un mouvement latéral. Sa première apparition est datée du 5 mars 2026 à 14 h 05 UTC. La fiche décrit un outil malveillant qui accède à la mémoire de LSASS pour en extraire des identifiants.

À 14 h 07 UTC, l’alerte SIEM nº 5, de sévérité critique, signale un accès en lecture à lsass.exe par un processus non signé. Le journal Sysmon associé rapporte un accès à ce même processus, avec la valeur granted=0x1010, et mentionne rundll32_helper.dll.

Ces éléments sont cohérents avec le comportement décrit dans la fiche BIN-03 et soutiennent l’hypothèse d’une tentative de collecte d’identifiants sur le contrôleur de domaine.

Technique ATT&CK retenue : T1003.001 — LSASS Memory, dans la tactique Credential Access. Cette technique décrit la recherche d’éléments d’authentification dans la mémoire du processus LSASS.

Impact potentiel : la récupération d’identifiants utilisables pourrait permettre d’accéder à d’autres ressources avec les droits des comptes concernés. La présence de cette activité sur un contrôleur de domaine rend le risque particulièrement important, sans démontrer à elle seule une compromission de tous les comptes du domaine.

Limites : le journal fourni documente un accès au processus, mais ne montre ni les données lues ni les identifiants effectivement récupérés. La fiche décrit une extraction d’identifiants ; son résultat n’est pas directement vérifiable dans les traces fournies. Le journal simplifié mentionne une DLL sans préciser le processus qui la charge, son compte d’exécution ou ses privilèges.

L’accès observé le 5 mars ne permet pas d’expliquer la connexion RDP du 4 mars : aucun élément ne démontre une collecte antérieure d’identifiants.

Sources : 01_fiches_analyse_binaires.md, fiche BIN-03 ; 03_alertes_siem_12.csv, alerte nº 5 ; 05_journaux_bruts.log, événement Sysmon du 5 mars 2026 à 14 h 07 UTC.

Un compte de service est une identité utilisée par un programme ; un service Windows est un programme qui fonctionne en arrière-plan. Le nom `svc-backup-temp` ne suffit donc pas à prouver la création d’un service Windows.

4.8. Création et suppression du compte svc-backup-temp

Le 5 mars 2026, l'alerte SIEM nº 9 signale sur dc-01 la création puis la suppression rapide du compte svc-backup-temp. Son détail indique une création à 14 h 10 et une suppression à 14 h 55. L'indicateur nº 37 situe également sa première observation à 14 h 10, avec une cote Admiralty B2.

Le journal Security, horodaté à 14 h 12, mentionne les événements 4720 et 4726, correspondant à la création et à la suppression d'un compte utilisateur. Cette ligne résume toutefois les deux opérations et indique une suppression « 45 minutes plus tard ». Elle ne permet pas de vérifier séparément leurs horaires exacts.

Correspondance ATT&CK proposée : T1136 — Create Account. La création du compte est documentée ; son utilisation par l'attaquant pour maintenir un accès reste une hypothèse. Le domaine et l'identifiant unique du compte ne sont pas fournis, ce qui limite le choix d'une sous-technique précise.

L'alerte nº 9 porte l'étiquette T1543.003 — Windows Service. Cette étiquette ne correspond pas directement aux événements de création et de suppression d'un compte. La fiche BIN-03 décrit séparément un service Windows créé puis supprimé : cette description soutient T1543.003, mais aucun journal d'installation de service ni nom de service n'est fourni. Nous ne pouvons pas affirmer que ce service porte le nom svc-backup-temp.

Incohérence chronologique : le journal RDP du 4 mars mentionne déjà un compte nommé svc-backup-temp, avant la création décrite le 5 mars. Sans identifiant unique ni domaine du compte, nous ne pouvons pas déterminer s'il s'agit du même compte, d'un homonyme ou d'une erreur du dossier.

Limites : l'auteur de la création, les droits attribués, les groupes d'appartenance et les usages du compte ne sont pas précisés. Sa suppression rapide ne démontre pas, à elle seule, une volonté d'effacer les traces.

Sources : 01_fiches_analyse_binaires.md, fiche BIN-03 ; 02_indicateurs_40.csv, indicateur nº 37 ; 03_alertes_siem_12.csv, alerte nº 9 ; 05_journaux_bruts.log, événements Security des 4 et 5 mars 2026.

5. Préparation locale des données avant exfiltration

Selon la fiche BIN-03, rundll32_helper.dll écrit un fichier chiffré dans C:\Windows\Temp avant l'exfiltration.

L'indicateur nº 39 identifie le fichier C:\Windows\Temp~df3a9.tmp comme un fichier de collecte chiffré, observé pour la première fois le 5 mars 2026 à 14 h 40 UTC, avec une cote Admiralty B2.

L'indicateur nº 12 fournit l'empreinte SHA-256 d'une archive chiffrée présentée comme préparée avant exfiltration et associée à BIN-03. Sa première observation est datée de 14 h 45 UTC, avec une cote B2.

Technique ATT&CK retenue : T1074.001 — Local Data Staging, dans la tactique Collection. Le stockage local des données avant leur transfert correspond au comportement décrit dans la fiche BIN-03.

Limites : aucun journal fourni ne documente directement la création de ces fichiers. Leur contenu, leur taille et l'outil de préparation ne sont pas précisés. Nous ne pouvons pas établir que le fichier

temporaire et l’archive sont un même fichier, ni démontrer leur lien exact avec les données transférées ensuite.

Les horaires situent ces observations avant les premiers signes d’exfiltration à 15 h 30 UTC. Ils ne permettent pas de mesurer la durée réelle de préparation.

Sources : 01_fiches_analyse_binaires.md, fiche BIN-03 ; 02_indicateurs_40.csv, indicateurs nº 12 et nº 39.

Élément disponible	Ce qu’il permet d’affirmer	Sa limite
Journal Zeek du 5 mars à 15 h 31 UTC	Il rapporte un trafic sortant vers 203.0.113.28:8080, avec **2 469 135 790 octets**, annoté cleartext	Il ne fournit pas le contenu transféré ni le programme responsable
Alerte SIEM nº 10	Le SIEM qualifie ce trafic d’**exfiltration**, avec une sévérité critique	Cette qualification ne démontre pas quels fichiers ont été envoyés
Indicateur nº 24, coté B2	Le dossier associe cette destination à l’exfiltration et à BIN-03, avec une première observation à **15 h 30 UTC**	Le journal ne rattache pas directement la connexion à BIN-03
Empreinte SHA-256 de l’archive, indicateur nº 12	Le dossier fournit une empreinte de référence pour une archive présentée comme préparée avant exfiltration	Aucune empreinte du contenu réseau ne permet de confirmer que cette archive a été transférée

Les traces fournies documentent un transfert sortant important depuis dc-01 vers 203.0.113.28 sur le port 8080, signalé comme une exfiltration par le SIEM. Le journal rapporte 2 469 135 790 octets et décrit le trafic comme non chiffré. Le contenu transféré, le programme responsable et le lien avec l’archive préparée précédemment ne sont pas établis.

6. Exfiltration depuis dc-01

Le 5 mars 2026 à 15 h 31 UTC, l’alerte SIEM nº 10 signale une exfiltration depuis dc-01 vers 203.0.113.28 sur le port 8080. Le journal Zeek associé rapporte un volume sortant de 2 469 135 790 octets et décrit le trafic comme non chiffré, avec la mention « cleartext ».

L’indicateur nº 24 associe cette destination à une exfiltration liée à BIN-03, avec une première observation à 15 h 30 UTC et une cote Admiralty B2. Les horaires de première observation et de détection sont conservés séparément.

Ces éléments documentent un transfert sortant important, qualifié d’exfiltration par le SIEM et cohérent avec la préparation de données décrite précédemment.

Correspondance ATT&CK proposée : T1048.003 — Exfiltration Over Unencrypted Non-C2 Protocol. Le transfert décrit en clair vers une destination distincte du C2 documenté soutient cette correspondance. Elle reste à confirmer, car le protocole applicatif et l’indépendance du canal par rapport au C2 ne sont pas directement établis par le journal.

Limites : le contenu transféré et le programme responsable ne sont pas fournis. Aucune comparaison d’empreintes ne démontre que l’archive de l’indicateur nº 12 a été envoyée. La mention d’un trafic en clair n’exclut pas le transfert d’un fichier préalablement chiffré.

Le volume exact représente environ 2,47 Go en unités décimales, ou 2,30 Gio en unités binaires. La mention « 2,3 Go » dans l’alerte semble donc refléter une différence d’unité ou d’arrondi.

Sources : 02_indicateurs_40.csv, indicateur nº 24 ; 03_alertes_siem_12.csv, alerte nº 10 ; 05_journaux_bruts.log, événement Zeek du 5 mars 2026 à 15 h 31 UTC.

6.1. Utilisation d’un domaine de repli

Le 6 mars 2026 à 03 h 10 UTC, l’alerte SIEM nº 11 signale sur srv-fichiers-02 un contact vers static-assets-cache[.]test, présenté comme une bascule après la perte du C2 principal.

Le journal Squid associé enregistre une requête HTTPS vers ce domaine, avec une réponse HTTP 200 et l’annotation « failover C2 ». L’indicateur nº 16 décrit déjà ce domaine comme une destination de repli, observée pour la première fois le 3 mars à 03 h 22 UTC, avec une cote Admiralty C3. Cette première observation précède donc le contact signalé le 6 mars.

Correspondance ATT&CK proposée : T1008 — Fallback Channels. Le rôle de repli est explicitement indiqué par le dossier et cohérent avec le contact observé.

Limites : le journal montre un contact réussi, mais ne contient ni les commandes échangées ni les traces de perte du C2 principal. Il ne permet pas d’identifier le programme responsable ou de confirmer le partage de certificat mentionné dans l’indicateur.

Sources : 02_indicateurs_40.csv, indicateur nº 16 ; 03_alertes_siem_12.csv, alerte nº 11 ; 05_journaux_bruts.log, événement Squid du 6 mars 2026 à 03 h 10 UTC.

6.2. Effacement du journal de sécurité

Le 7 mars 2026 à 09 h 02 UTC, l’alerte SIEM nº 12 signale une tentative d’effacement des journaux sur comptabilite-07 et mentionne la commande wevtutil cl Security.

Le journal Security associé rapporte l’événement 1102, avec la mention « audit log cleared ». Cette trace soutient un effacement effectif du journal de sécurité, au-delà de la seule tentative décrite dans l’alerte.

Technique ATT&CK retenue : T1070.001 — Clear Windows Event Logs. L’effacement peut réduire les traces disponibles pour l’investigation et est compatible avec une volonté de dissimulation.

Limites : l’identité de l’auteur, le processus à l’origine de l’action et l’étendue des événements perdus ne sont pas fournis. Cet effacement ne démontre ni la suppression de toutes les traces ni le départ de l’attaquant.

Sources : 03_alertes_siem_12.csv, alerte nº 12 ; 05_journaux_bruts.log, événement Security du 7 mars 2026 à 09 h 02 UTC.

7. Conclusion de la reconstitution

La chronologie soutient une intrusion sur trois hôtes, avec persistance, communications de commande, accès à LSASS et transfert sortant suspect. Les liens entre les hôtes restent partiellement établis. Le contenu transféré, la présence résiduelle de l’attaquant et son identité demeurent inconnus ; aucun chiffrement par rançongiciel n’est démontré.

8. Synthèse des techniques MITRE ATT&CK

Les correspondances ci-dessous reposent sur les comportements décrits dans les artefacts. « Retenue » signifie que les éléments permettent de conserver la technique dans l'analyse ; cela ne démontre pas nécessairement la réussite de l'action. « À confirmer » indique qu'une précision essentielle manque.

Comportement	Technique ATT&CK	Sources du dossier	Évaluation
Pièce jointe malveillante reçue par courriel	T1566.001 — Spearphishing Attachment	Fiche BIN-01	Retenue sur la base de la fiche ; courriel original absent
Ouverture du fichier malveillant	T1204.002 — Malicious File	Fiche BIN-01	Retenue sur la base du comportement décrit
Exécution de PowerShell	T1059.001 — PowerShell	Fiche BIN-01 ; alerte 1 ; journal du 2 mars à 08 h 31	Retenue ; incohérence entre classeur Excel et winword.exe
Téléchargement de BIN-02	T1105 — Ingress Tool Transfer	Fiches BIN-01 et BIN-02 ; indicateurs 13 et 29 ; alerte 2 ; journal à 08 h 42	Retenue ; empreinte du fichier transféré absente du journal
Persistance par valeur de registre Run	T1547.001 — Registry Run Keys / Startup Folder	Fiche BIN-01 ; indicateur 38	Retenue sur la base du dossier ; configuration et déclenchement non vérifiés
Persistance par tâche planifiée	T1053.005 — Scheduled Task	Fiche BIN-02 ; indicateur 36 ; alerte 3 ; journal à 08 h 46	Retenue ; création documentée, configuration complète inconnue
Communications de commande en HTTPS	T1071.001 — Web Protocols	Fiche BIN-02 ; indicateurs 14, 20 et 31 ; alerte 4 ; journal à 09 h 16	Retenue ; contenu des échanges et périodicité non vérifiables dans la trace unique
Chiffrement propre au canal de commande	T1573 — Encrypted Channel	Étiquette de la fiche BIN-02	À confirmer ; HTTPS seul ne suffit pas à établir cette technique
Balayage de services internes	T1046 — Network Service Discovery	Indicateur 25 ; alerte 6 ; journal du 3 mars à 10 h 13	Retenue ; résultats du balayage et programme responsable inconnus
Session RDP suspecte sur srv-fichiers-02	T1021.001 — Remote Desktop Protocol	Alerte 7 ; journal du 4 mars à 01 h 48 ; indicateur 26 à rapprocher	Usage de RDP documenté ; mouvement latéral malveillant proposé, origine non établie
Injection de code dans explorer.exe	T1055 — Process Injection	Alerte 8 ; journal du 4 mars à 11 h 05	Retenue au niveau général ; processus responsable inconnu
Injection par Process Hollowing	T1055.012 — Process Hollowing	Fiche BIN-02 ; étiquette de l'alerte 8	Décrite dans la fiche ; forme précise non démontrée pour l'événement du serveur
Accès à la mémoire LSASS	T1003.001 — LSASS Memory	Fiche BIN-03 ; alerte 5 ; journal du 5 mars à 14 h 07	Retenue ; récupération effective d'identifiants non vérifiable

Création du compte svc-backup-temp	T1136 — Create Account	Indicateur 37 ; alerte 9 ; journal du 5 mars à 14 h 12	Création documentée ; finalité de persistance proposée, identité et chronologie à clarifier
Création puis suppression d’un service Windows	T1543.003 — Windows Service	Fiche BIN-03	Retenue sur la base de la fiche ; service non identifié, distinct du compte utilisateur
Préparation locale des données	T1074.001 — Local Data Staging	Fiche BIN-03 ; indicateurs 12 et 39	Retenue sur la base du dossier ; contenu et lien entre les fichiers inconnus
Transfert sortant décrit comme une exfiltration en clair	T1048.003 — Exfiltration Over Unencrypted Non-C2 Protocol	Indicateur 24 ; alerte 10 ; journal du 5 mars à 15 h 31	À confirmer au niveau de la sous-technique ; protocole et indépendance du canal C2 non établis
Contact d’un domaine de repli	T1008 — Fallback Channels	Indicateur 16 ; alerte 11 ; journal du 6 mars à 03 h 10	Correspondance proposée ; rôle de repli décrit, bascule non directement vérifiable
Effacement du journal de sécurité Windows	T1070.001 — Clear Windows Event Logs	Alerte 12 ; journal du 7 mars à 09 h 02	Retenue ; trace d’effacement présente, auteur inconnu

Les fiches, indicateurs, alertes et journaux appartiennent au même corpus pédagogique : leurs recoupements ne constituent pas des confirmations indépendantes. Les cotes Admiralty fournies pour les indicateurs restent distinctes de l’évaluation des correspondances ATT&CK.

La présence de techniques communes à plusieurs groupes ne suffit pas à attribuer l’incident à un acteur précis.

9. Application du Diamond Model à l’incident Helios Energy

Le Diamond Model relie quatre dimensions d’un événement : l’adversaire, la capacité employée, l’infrastructure utilisée et la victime. Dans ce dossier, l’adversaire reste non identifié. Regrouper les événements dans une même investigation ne démontre pas automatiquement qu’un seul acteur les a tous réalisés.

Événement	Adversaire	Capacité	Infrastructure	Victime	Preuves et limites
Accès initial du 2 mars	Non identifié	BIN-01, document à macro lançant PowerShell	Courriel avec pièce jointe ; expéditeur et serveur de messagerie non fournis	Helios Energy, poste comptabilite-07	Fiche BIN-01, alerte 1 et journal Sysmon. Incohérence entre le classeur Excel et le processus winword.exe
Téléchargement de la seconde charge	Non identifié	Fonction de téléchargement décrite pour BIN-01 ; charge téléchargée	cdn-svc-update[.]test et URL de téléchargement	comptabilite-07	Fiches BIN-01 et BIN-02, indicateurs 13 et 29, alerte 2

		BIN-02			et journal Squid. Le journal ne fournit pas l’empreinte du fichier transféré
Communications de commande et contrôle	Non identifié	BIN-02, balise de commande et contrôle selon sa fiche	api-telemetry-eu[.]test, URL /v2/beacon et adresse de résolution 198.51.100.24	comptabilite-07	Fiche BIN-02, indicateurs 14, 20 et 31, alerte 4 et journal Zeek. Le contenu des échanges et le processus responsable ne sont pas visibles dans le journal
Session RDP du 4 mars	Non identifié ; caractère malveillant proposé	Accès distant RDP avec le compte nommé svc-backup-temp	Connexion distante dont la machine d’origine reste inconnue	srv-fichiers-02	Alerte 7 et journal Security. L’adresse de l’indicateur 26 n’est pas directement confirmée ; chronologie du compte incohérente
Accès à LSASS du 5 mars	Non identifié	BIN-03, outil de collecte d’identifiants selon sa fiche	Moyen d’arrivée sur dc-01 non documenté	dc-01 et éléments d’authentification potentiellement exposés	Fiche BIN-03, alerte 5 et journal Sysmon. L’accès est rapporté, mais les identifiants effectivement récupérés restent inconnus
Transfert sortant du 5 mars	Non identifié	Transfert de données ; programme responsable inconnu	Destination 203.0.113.28 sur le port 8080	dc-01 ; données transférées non identifiées	Indicateur 24, alerte 10 et journal Zeek. Le rattachement à BIN-03 est indiqué par le dossier, sans confirmation directe dans la

					trace réseau
Contact de repli du 6 mars	Non identifié	Fonction de repli décrite par le dossier ; programme responsable inconnu	static-assets-cache[.]test	srv-fichiers-02	Indicateur 16, alerte 11 et journal Squid. Le contact est documenté, mais la perte du C2 principal n’est pas directement visible

10. Relations documentées

La fiche BIN-01 décrit le téléchargement de BIN-02. Le journal Squid documente un téléchargement depuis l’infrastructure indiquée, sans confirmer l’empreinte du contenu.

La fiche BIN-02 relie cette charge à des communications de commande et contrôle. L’alerte et le journal réseau sont cohérents avec la destination fournie, mais ne permettent pas d’attribuer directement la connexion à un processus.

La fiche BIN-03 décrit un accès à LSASS et une préparation locale de données. Les traces documentent également un transfert sortant depuis dc-01, sans établir que les fichiers préparés sont ceux qui ont été envoyés.

Relations restant à démontrer

Le dossier ne démontre pas le trajet exact entre comptabilite-07, srv-fichiers-02 et dc-01. Il ne précise pas comment BIN-02 ou BIN-03 ont été déployés sur les autres machines.

L’identité de l’adversaire, la propriété des infrastructures, le contenu exfiltré et le lien causal entre chaque étape restent partiellement ou entièrement inconnus.

Apport du modèle à l’analyse

Le modèle met en évidence un ensemble d’activités compatible avec une intrusion comprenant accès initial, installation d’outils, communications de commande, activité sur plusieurs hôtes et exfiltration signalée. Il permet d’organiser les relations à représenter dans MISP et dans le graphe, tout en conservant les incertitudes.

Le sommet « adversaire » reste non attribué. La piste FIN7/Carbanak sera examinée dans la note d’attribution ; elle ne constitue pas une identité démontrée par ce modèle.

Sources : 01_fiches_analyse_binaires.md ; 02_indicateurs_40.csv ; 03_alertes_siem_12.csv ; 05_journaux_bruts.log. Les références précises et les horaires sont détaillés dans la reconstitution chronologique.

11. Matrice des risques confidentialité intégrité disponibilité

Cette matrice distingue les atteintes documentées des conséquences potentielles. La criticité proposée repose sur le rôle des actifs et les comportements observés ; elle ne correspond pas automatiquement à la sévérité des alertes SIEM.

Actif	Confidentialité	Intégrité	Disponibilité	Criticité argumentée
comptabilite-07 — poste d’entrée	Risque élevé : la présence d’une charge malveillante et de communications de commande expose potentiellement les informations accessibles au poste. Aucun vol précis de documents comptables n’est démontré	Atteinte documentée par les mécanismes de persistance décrits dans le dossier et l’effacement du journal de sécurité	Aucune interruption de service documentée. Une indisponibilité pourrait résulter de l’activité malveillante ou des mesures de confinement	Élevée : poste compromis servant de point d’entrée, avec persistance et communications externes
srv-fichiers-02 — serveur de fichiers	Risque élevé : une session distante suspecte et une injection de code pourraient exposer les fichiers accessibles. Leur consultation ou leur exfiltration depuis ce serveur ne sont pas démontrées	L’alerte et le journal décrivent une activité compatible avec une injection dans explorer.exe. Aucune modification des fichiers partagés n’est documentée	Aucune panne ni interruption des partages documentée. Un confinement pourrait affecter les utilisateurs dépendant du serveur	Élevée : activité suspecte sur un serveur pouvant héberger des données partagées ; périmètre des accès inconnu
dc-01 — contrôleur de domaine	Risque critique : accès à LSASS et transfert sortant important signalé comme une exfiltration. Les identifiants récupérés et le contenu transféré restent inconnus	Création et suppression d’un compte rapportées ; présence de BIN-03 décrite dans la fiche. Les droits du compte et les autres modifications du domaine ne sont pas établis	Aucune interruption de l’authentification documentée. Une défaillance ou un confinement mal préparé pourrait perturber les services dépendant du domaine	Critique : actif central de l’authentification, avec activité de collecte d’identifiants et transfert sortant important

12. Priorités de traitement proposées

1. dc-01 : préserver les preuves, examiner les accès à LSASS, les comptes et les flux sortants. Préparer le confinement avec l’équipe chargée de l’annuaire afin de limiter les perturbations de l’authentification.
2. comptabilite-07 : préserver les traces disponibles, contenir les communications suspectes et examiner les mécanismes de persistance ainsi que les comptes utilisés sur le poste.
3. srv-fichiers-02 : examiner la session RDP, l’injection et le contact du domaine de repli ; déterminer quels fichiers et comptes étaient accessibles.

Les trois actifs doivent être traités de façon coordonnée. L’ordre proposé indique les enjeux principaux et ne justifie pas de retarder le confinement d’un autre hôte présentant une activité malveillante en cours.

Limites de l’évaluation

Aucune interruption des services, destruction de données ou opération de chiffrement par rançongiciel n’est démontrée. L’absence de trace dans le dossier ne prouve toutefois pas l’absence d’impact.

Le rôle de fournisseur d’énergie et d’opérateur d’importance vitale rend les conséquences métier potentiellement importantes, mais aucun élément ne démontre une atteinte aux systèmes industriels ou une interruption de la fourniture d’énergie.

Les mesures proposées sont des recommandations pour le scénario étudié. Elles n’ont pas été exécutées ni validées sur un système réel.

Sources : 01_fiches_analyse_binaires.md ; 03_alertes_siem_12.csv ; 04_memo_technique_SOC.md ; 05_journaux_bruts.log. Les observations et leurs limites sont détaillées dans la reconstitution chronologique.

13. Graphe de relations CTI

Relations CTI de l’incident Helios Energy : synthèse des trois binaires, des techniques MITRE ATT&CK et des indicateurs associés. Les liens reposent sur les fiches d’analyse et les commentaires MISP ; ils ne démontrent pas tous une causalité directement observée. Les empreintes sont abrégées pour faciliter la lecture.

Ce graphe présente les relations enregistrées pour les trois binaires ; il ne représente pas l’ensemble de la chronologie de l’incident.

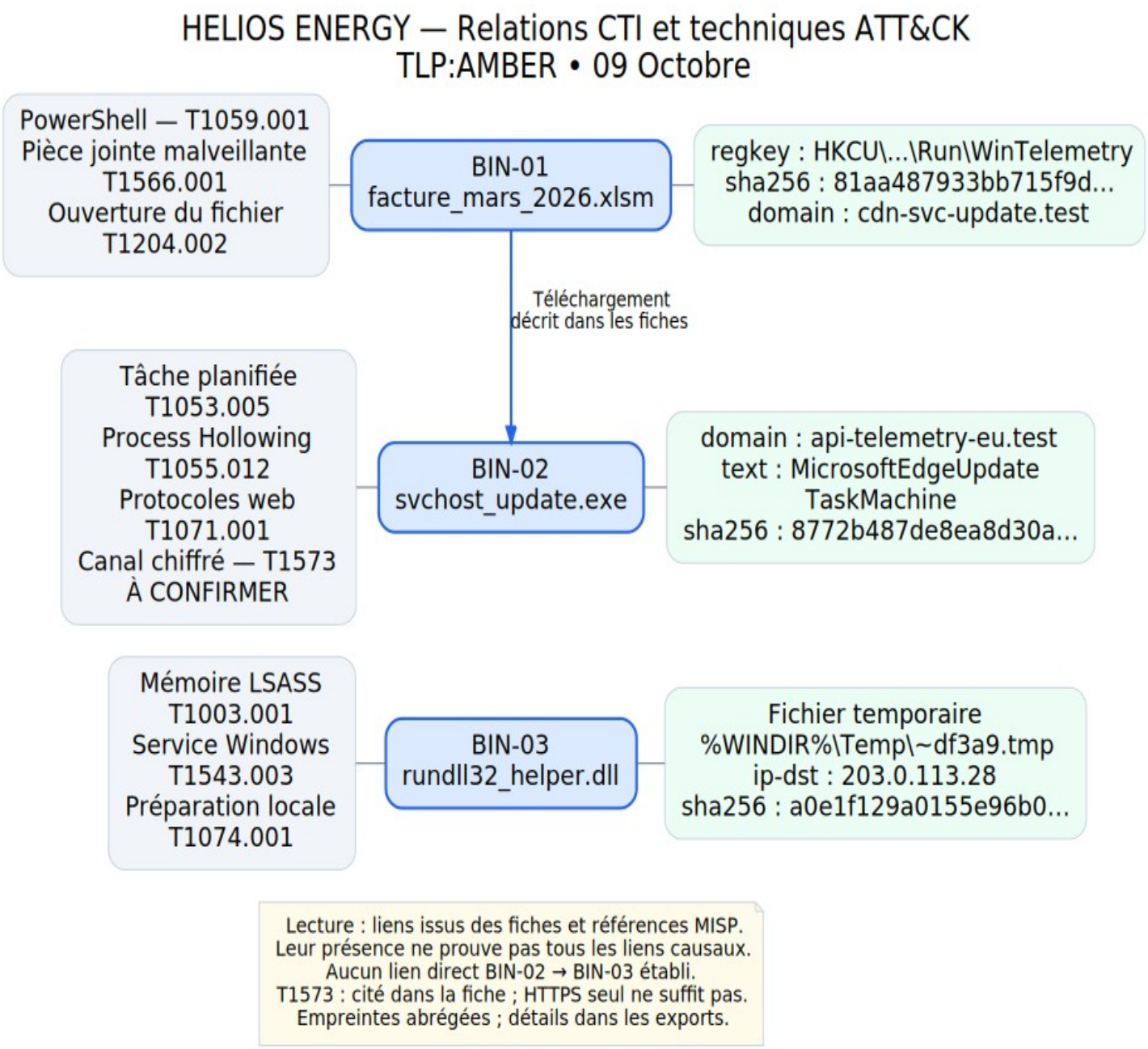


Figure 1: Relations CTI de l'incident Helios Energy : synthèse des trois binaires, des techniques MITRE ATT&CK et des indicateurs associés. Les liens reposent sur les fiches d'analyse et les commentaires MISP ; ils ne démontrent pas tous une causalité directement observée. Les empreintes sont abrégées pour faciliter la lecture.

Export STIX :

Export direct en erreur, conversion séparée en STIX 2.1, relations vides normalisées en `related-to`, commentaires conservés dans le JSON MISP et le fichier complémentaire. Mentionne les fichiers livrés sans coller leur contenu.